

ПРИМЕНЕНИЕ АППАРАТА НЕЙРОСЕТЕВЫХ ТЕХНОЛОГИЙ ДЛЯ ОПРЕДЕЛЕНИЯ АКТУАЛЬНЫХ УГРОЗ БЕЗОПАСНОСТИ ИНФОРМАЦИИ ИНФОРМАЦИОННЫХ СИСТЕМ

Соловьев

Сергей Вениаминович,

к.т.н, начальник управления
Государственного научно-
исследовательского испытательного
института проблем технической защиты
информации Федеральной службы по
техническому и экспортному контролю
России,
г.Воронеж, Россия,
sersol@mail.ru

Мамута

Владимир Владимирович,

научный сотрудник Государственного
научно-исследовательского
испытательного института проблем
технической защиты информации
Федеральной службы по техническому
и экспортному контролю России,
г.Воронеж, Россия,
zolton007@mail.ru, priveten@yandex.ru

АННОТАЦИЯ

Ключевые слова:

банк данных угроз безопасности
информации; уязвимости программного
обеспечения; угрозы безопасности
информации; веб-приложения;
нейронные сети.

Количество информационных систем различного назначения растет с каждым годом. Одним из обязательных этапов формирования требований к защите информации, содержащейся в информационной системе, является определение актуальных угроз безопасности информации, реализация которых может привести к нарушению безопасности информации в информационной системе, и разработка на этой основе модели угроз безопасности информации, включающей описание возможных уязвимостей применяемого в информационной системе программного обеспечения. ФСТЭК России ведет банк данных угроз безопасности информации, содержащий перечень угроз безопасности информации и сведения об уязвимостях программного обеспечения. На сегодняшний день информация об угрозах безопасности информации в сформированном банке данных существуют отдельно от сведений об уязвимостях, в связи с чем поиск угроз безопасности информации, актуальных для конкретной информационной системы, в банке данных необходимо производить вручную, что является весьма трудоемкой задачей, зависящей от масштаба информационной системы. Для автоматизации процедуры получения сведений об актуальных для информационной системы угрозах безопасности информации на основе данных об уязвимостях программного обеспечения, входящего в состав информационной системы, предлагается использовать аппарат нейросетевых технологий. В качестве исходных данных для обучения нейронных сетей предлагается использовать сведения об уязвимостях программного обеспечения, накопленные в банке данных. В результате выполненной работы прошел успешную апробацию предложенный метод выявления актуальных для информационной системы угроз безопасности информации на основе сведений об уязвимостях программного обеспечения. Эмпирическим путем установлена оптимальная топология нейронной сети. Разработан прототип программного продукта, решающий проблему установления связей между угрозами безопасности информации и уязвимостями программного обеспечения в банке данных угроз безопасности информации. Предложены перспективные направления развития в предметной области: создание прикладных нейронных сетей, совершенствование их топологий, а также разработка и дальнейшее совершенствование процедур их обучения.

Проблема анализа и оценки угроз безопасности информации, обрабатываемой в информационных системах (далее - ИС), в настоящее время приобрела особую актуальность. Это связано, в первую очередь, с выявлением все большего числа уязвимостей программного обеспечения, применяемого в ИС. Количество известных уязвимостей в настоящее время оценивается десятками тысяч [1]. Статистика обнаружения уязвимостей по данным NVD (национальной базы уязвимостей США) приведена на рис. 1. Задача исследования уязвимостей программного обеспечения (далее - ПО), применяемого в ИС различного назначения, становится актуальней с каждым годом, что обусловлено ростом зависимости безопасности жизнедеятельности населения большинства стран от безопасности функционирования неуклонно возрастающего числа ИС.

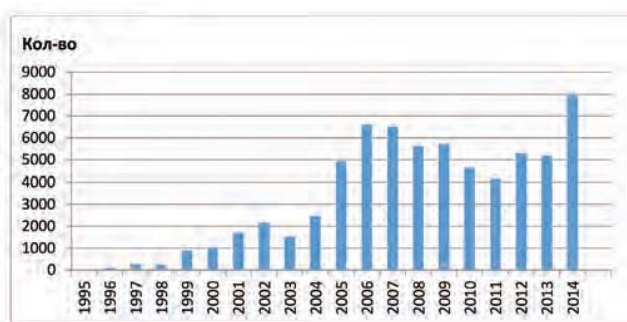


Рис. 1. Статистика количества найденных уязвимостей по годам

Под уязвимостью программного обеспечения (далее – уязвимость) понимается свойство ПО, обуславливающее возможность реализации угрозы безопасности информации (далее – угроза) с использованием этой уязвимости. Под угрозой понимается совокупность условий и факторов, создающих потенциальную или реально существующую опасность нарушения безопасности информации.

Особенно активно работа по выявлению уязвимостей проводится за рубежом. В частности, в США сбор данных об уязвимостях, их систематизация и учет осуществляются как органами государственной власти, так и частными компаниями, которые ведут базы данных с открытым и ограниченным доступом. К таким базам относятся CVE (общепринятый словарь уязвимостей, формируется корпорацией MITRE), NVD (национальная база уязвимостей США, поддерживается национальным институтом стандартов и технологий США), OSVDB (открытая база данных уязвимостей, создана тремя некоммерческими организациями и ведется волонтерами со всего мира), BID (BugtraqID – коммерческая база данных уязвимостей с платным доступом), Secunia (платная база данных уязвимостей датской компании Secunia), ICS-CERT (база данных уязвимостей ПО систем управления, созданная и поддерживаемая Департаментом национальной безопасности США) и др.

По заказу Федеральной службы по техническому и экспортному контролю (ФСТЭК России) совместно с заинтересованными федеральными органами исполнительной власти и организациями сформирован и введен в эксплуатацию

с 1 марта 2015 года банк данных угроз безопасности информации (далее – Банк данных) [3]. Доступ к Банку данных осуществляется через сеть «Интернет» (адрес: bdu.fstec.ru).

Разработанный Банк данных предназначен для систематизации и поддержания в актуальном состоянии в рамках единой базы данных сведений о выявленных уязвимостях и угрозах наиболее характерных для государственных систем, информационных систем персональных данных и автоматизированных систем управления производственными и технологическими процессами на критически важных объектах, а также о типах и возможностях источников угроз (возможностях нарушителей по эксплуатации уязвимостей) при решении задач:

- анализа и выявления уязвимостей ИС на этапах создания и эксплуатации ИС;

- разработки и поддержания в актуальном состоянии программных средств контроля (анализа) защищенности информации в ИС;

- разработки систем защиты информации от несанкционированного доступа;

- оценки соответствия (включая работы по сертификации) средств технической защиты информации, применяемых в ИС и др.

По состоянию на октябрь 2015 года Банк данных содержит сведения более чем о 12000 уязвимостях и перечень из 182 угроз. Сведения об уязвимостях в Банке данных включают довольно обширную информацию об уязвимом ПО и условиях эксплуатации уязвимостей (по каждой уязвимости дается её описание по 20 полям). Информация об угрозах, включенных в состав Банка данных, представляет собой обобщенный перечень основных угроз, потенциально опасных для ИС. Перечень угроз составлен на основе анализа зарубежных наработок в области описания угроз безопасности информации, таких как CAPEC (англ. Common Attack Pattern Enumeration and Classification – перечень и классификация общеизвестных схем атак), WASC-TC (англ. Web Application Security Consortium Threat Classification – классификация угроз консорциума по безопасности веб-приложений), а также отечественных базовых моделей угроз безопасности информации по ряду направлений [2, 4, 5].

При построении модели угроз для конкретной ИС для определения возможных угроз проводится её анализ как объекта защиты. Рассматриваются основные источники угроз, потенциальные уязвимости компонентов ИС и возможные способы их реализации [2, 3].

Угрозы представляют собой совокупность обобщенных классов возможных источников угроз, уязвимостей программного и аппаратного обеспечения, способов реализации угроз, объектов воздействия (носителей защищаемой информации) и возможных деструктивных действий, которые эти угрозы могут оказать на ИС [2, 3]. Реализованный функционал Банка данных позволяет осуществлять поиск угроз в Банке данных по сведениям об источниках угроз, последствиям реализации (нарушение конфиденциальности, целостности, доступности), а также по их названиям.

Поиск уязвимостей в Банке данных реализован по большинству полей описания уязвимостей. Таким образом,

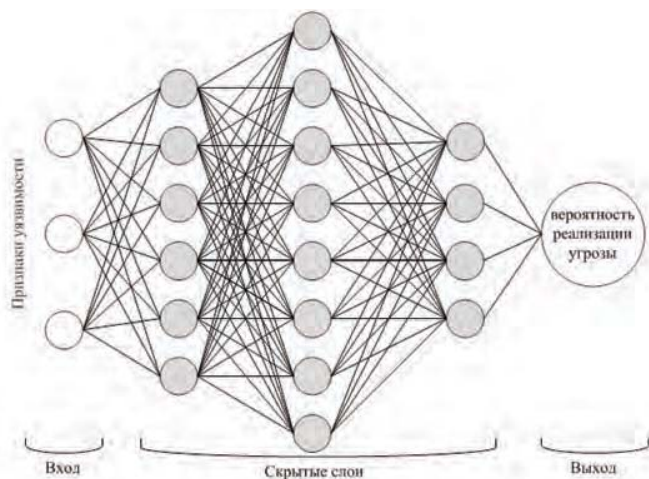


Рис. 2. Оптимальная топология нейронной сети

обладая перечнем программного обеспечения, установленного на конкретной ИС, при помощи Банка данных можно получить сведения об известных уязвимостях программного обеспечения, входящего в состав ИС. Полный перечень записей об уязвимостях, имеющихся в Банке данных, также доступен для загрузки в виде файла.

Располагая сведениями об уязвимостях конкретной ИС можно определить актуальные для нее угрозы, реализация которых зависит от уязвимостей. На сегодняшний день сведения об угрозах в Банке данных существуют отдельно от записей об уязвимостях. Это связано с большой трудоёмкостью работ по установлению прямых связей между ними. Таким образом, в настоящее время поиск угроз, актуальных для конкретной ИС, в Банке данных необходимо производить вручную, что является весьма трудоёмкой задачей, зависящей от масштаба ИС.

В связи с этим актуальной является задача разработки методов и средств автоматизации установления связей между угрозами и уязвимостями.

Для того, чтобы установить, может ли повлечь эксплуатация уязвимости какую-либо угрозу, необходимо произвести анализ значений совокупности признаков этой уязвимости, сравнив их с соответствующими значениями «эталонных» примеров признаков уязвимостей. Такие «эталонные» примеры можно получить методом экспертной оценки сведений об уязвимостях, накопленных в Банке данных, осуществив из него специальные выборки данных по определенным критериям.

Для каждой угрозы записи об уязвимостях в Банке данных можно условно разделить на два класса (группы): уязвимости, эксплуатация которых может повлечь её реализацию, и уязвимости, эксплуатация которых не влияет на реализацию данной угрозы. Таким образом, необходимо решать задачу классификации «свой-чужой» для каждой уязвимости ИС по отношению к каждой угрозе. Для автоматизации этого процесса предлагается использовать методы искусственных нейронных сетей. Обучение нейронных сетей предлагается

производить на примерах, полученных в результате осуществления специальных выборок данных об уязвимостях [10, 11].

Для каждой угрозы, реализация которой зависит от наличия в ИС уязвимостей, необходимо создать нейронную сеть с количеством входов, равным выбранному количеству признаков уязвимостей и одним выходом, на котором будет формироваться вероятность реализации этой угрозы.

Подготовка нейронной сети является довольно трудоёмким процессом который включает реализацию обучающих выборок с примерами уязвимостей, подбор конфигурации сети, выбор функций активации нейронов, обучение сети и другие процедуры. Для проверки предлагаемого метода автоматизации процесса определения угроз, которые может повлечь реализация уязвимости, было принято решение реализовать его на примере угроз, актуальных для веб-приложений. Такое решение связано с интенсивным ростом популярности этого вида программного обеспечения. На сегодняшний день большинство настольных офисных приложений имеют аналог, работающий через веб-браузер, крупные организации все активнее используют разнообразные веб-приложения – официальные сайты компаний, системы управления ресурсами предприятий, системы электронного документооборота, системы управления проектами и задачами, электронные торговые площадки, системы дистанционного банковского обслуживания, порталы государственных услуг и прочие. Уязвимости в веб-приложениях становятся одним из основных векторов атак на ИС [6].

С целью составления списка угроз, актуальных для веб-приложений, был проведен анализ публикаций российских и иностранных компаний, занимающихся исследованием безопасности веб-приложений, в сети «Интернет». За основу для составления указанного перечня угроз был взят постоянно актуализируемый список OWASP Top 10 сообщества OWASP, в котором перечислены наиболее опасные виды уязвимостей в веб-приложениях. Этот список считается лучшей практикой устранения уязвимостей веб-приложений, на него ссылаются большинство организаций, занимающихся тестированием веб-приложений на предмет уязвимостей [7, 8]. Также были использованы результаты ежегодных исследований российской компании Positive Technologies, посвященные анализу данных, полученных при проведении работ по анализу защищенности веб приложений и обзору наиболее распространенных уязвимостей [9]. Далее представлен перечень угроз из Банка данных, для которых были созданы и обучены нейронные сети:

УБИ.006: Угроза внедрения кода или данных;

УБИ.015: Угроза доступа к защищаемым файлам с использованием обходного пути;

УБИ.017: Угроза доступа/перехвата/изменения HTTP cookies;

УБИ.041: Угроза межсайтового скриптинга;

УБИ.042: Угроза межсайтовой подделки запроса;

УБИ.140: Угроза приведения системы в состояние «отказ в обслуживании»;

УБИ.175: Угроза «фишинга».

С целью создания, настройки и конфигурирования нейронных сетей был разработан программный модуль для Бан-

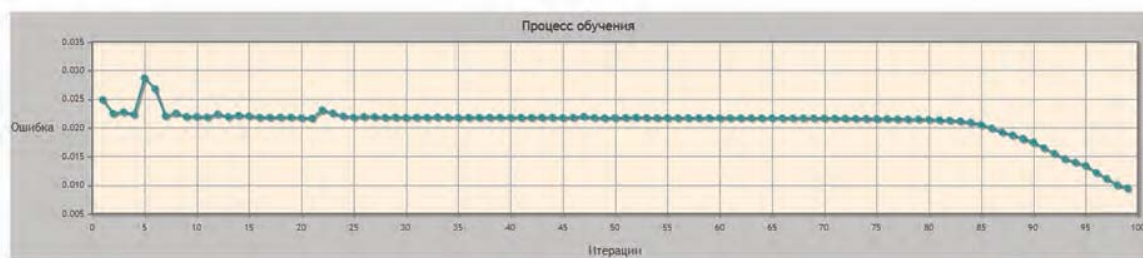


Рис. 3. График обучения нейронной сети

ка данных, позволяющий создавать нейронные сети с произвольным количеством нейронов во входном, выходном и скрытых слоях, выбирать количество итераций обучения сети с возможностью вывода ошибки после каждой итерации. Реализована возможность выбора функций активации нейронов скрытых слоёв и выходного слоя, а также прочий функционал предусматривающий, в том числе, вывод графика обучения (вывод ошибки после каждого цикла обучения) для контроля за процессом обучения нейронной сети.

Указанная функциональность разработанного модуля обусловлена необходимостью подбора оптимальных параметров при создании сетей для каждой из угроз. Однако эмпирическим путем установлено, что для большинства из созданных нейронных сетей оптимальной является топология, представленная на рис. 2. Обучение нейросетей такой топологией происходило за минимальное количество итераций с минимальными значениями среднеквадратичной ошибки после каждой итерации.

В качестве входных параметров нейронной сети используются формализованные значения признаков уязвимостей, получаемые из записей об уязвимостях, содержащихся в Банке данных. На выходе сети формируется числовое значение вероятности реализации угрозы, для которой создана данная нейронная сеть.

Для проверки предложенного метода при обучении нейросетей было использовано три признака уязвимостей: класс уязвимости, тип ошибки и тип программного обеспечения. Формирование обучающих выборок реализовано посредством формирования SQL-запросов к базе данных Банка данных. Для каждой угрозы сформированы выборки двух типов: примеры уязвимостей, эксплуатация которых может повлечь реализацию этой угрозы и уязвимостей, эксплуатация которых на реализацию данной угрозы не влияет.

На рис.3 представлен график обучения нейронной сети для угрозы УБИ.006: Угроза внедрения кода или данных.

После обучения нейронная сеть и обучающая выборка сохраняются в файлы. Далее для проверки возможности реализации какой-либо из угроз, для которых созданы нейронные сети, на вход подаются формализованные признаки уязвимости. При вызове программы формируется массив нейронных сетей, каждая из которых запускается с переданными значениями на входе. В результате работы программы пользователь получает отсортированный по значению вероятности список угроз, реализация которых возможна при на-

личии в ИС уязвимости, признаки которой были переданы.

В результате выполненной работы прошел успешную апробацию предложенный метод выявления актуальных для ИС угроз. Получен прототип программного продукта решающий проблему установления связей между угрозами и уязвимостями в банке данных угроз безопасности информации. Перспективными направлениями развития в предметной области являются создание прикладных нейронных сетей, совершенствование их топологий, а также разработка и дальнейшее совершенствование процедур их обучения.

Литература

1. National Vulnerability Database (NVD). URL: <https://nvd.nist.gov/> (дата обращения 16.10.2015).
2. Базовая модель угроз безопасности персональных данных при их обработке в информационных системах персональных данных // Утверждена заместителем директора ФСТЭК России 15 февраля 2008 г.
3. Соловьев С., Мамута В. Свидетельство о государственной регистрации базы данных №2015621561. Банк данных угроз безопасности информации «UBI 1.0».
4. Common Attack Pattern Enumeration and Classification (CAPEC). URL: <https://capec.mitre.org> (дата обращения: 20.10.2015).
5. The Web Application Security Consortium (WASC). URL: <http://www.webappsec.org/>, (дата обращения 12.10.2015).
6. Positive Technologies. Уязвимости веб-приложений: ситуация не улучшается. URL: <http://habrahabr.ru/company/pt/blog/268779/> (дата обращения: 16.10.2015).
7. IBM developerWorks. Проверьте ваши приложения на уязвимости из списка OWASP Top 10 за 2013 год. URL: <https://www.ibm.com/developerworks/ru/library/se-owasp-top10/> (дата обращения: 15.10.2015).
8. Статистика уязвимостей веб-приложений (2014 г.). URL: http://www.ptsecurity.ru/lab/analytics/WEB_APP_VULNERABILITY_2014.A4.RUS.242465.14.OCT.2015.pdf (дата обращения: 16.10.2015).
9. Welcome to OWASP the free and open software security community. URL: https://www.owasp.org/index.php/Main_Page (дата обращения: 20.10.2015).
10. Барский А.Б. Нейронные сети: распознавание, управление, принятие решений. М.: Финансы и статистика. 2004. 176 с.
11. Заенцев И.В. Нейронные сети: основные модели. Воронеж: Изд-во Воронежского госуд. ун-та, 1999. 76 с.

Для цитирования:

Соловьев С.В., Мамута В.В. Применение аппарата нейросетевых технологий для определения актуальных угроз безопасности информации информационных систем // Научные технологии в космических исследованиях Земли. 2016. Т. 8. № 5. С. 78–82.

USING NEURAL NETWORK TECHNOLOGIES APPARATUS FOR DETERMINATION OF THE ACTUAL INFORMATION SECURITY THREATS FOR INFORMATION SYSTEMS

Sergey V. Solovyov,

Voronezh, Russia, sersol@mail.ru

Vladimir V. Mamuta,

Voronezh, Russia, zolton007@mail.ru

Abstract

The number of information systems for various purposes is growing every year. One of obligatory stages of formation of requirements to protection of information contained in the information system is the identification of relevant threats to information security, the implementation of which may lead to violation of information security in the information system, and development on this basis of model of threats of information security, including a description of possible vulnerabilities used in the information system software. The FSTEC of Russia maintains a database of security threats to information containing the list of threats to the security of information and information about software vulnerabilities. To day information about the threats to the security of information in the data Bank, there are formed separately from information about the vulnerability, the search for threats to information security, relevant to a particular information system, the database must be done manually, which is a very time consuming task, depending on the scale of the information system. To automate the procedure of obtaining information relevant to information systems threats to information security on the basis of the data about the vulnerabilities of the software that is part of the information system, it is proposed to use the apparatus of neural networks. As input data for training neural networks is proposed to use information about the software vulnerabilities accumulated in the data Bank. As a result of the work performed has been successfully tested the proposed method to identify relevant for information system threats of information security on the basis of information about software vulnerabilities. Empirically determined the optimal topology of a neural network. Developed a prototype software product that solves the problem of establishing links between threats to information security and software vulnerabilities in the data security threats information. Suggested promising directions of development in the subject area: applied neural networks, the improvement of their topologies, as well as the development and further improvement of procedures of their learning.

Keywords: the database of threats to information security; software vulnerabilities; threats to information security; web applications; neural networks.

References

1. National Vulnerability Database (NVD). URL: <https://nvd.nist.gov/> (date of access 16.10.2015).
2. Bazovaja model' ugroz bezopasnosti personal'nyh dannyh pri ih obrabotke v informacionnyh sistemah personal'nyh dannyh [The basic model of threats to the security of personal data during processing in personal data information systems] // Utverzhdena zamestitelem direktora FSTEC Rossii [Approved by the Deputy Director FSTEC] 15 февраля 2008 г. (In Russian).
3. Certificate of state registration of the databases No. 2015621561. Bank dannyh ugroz bezopasnosti informacii [The certificate of state registration database 2015621561 Bank data security threats information]. Solov'ev S., Mamuta V. (In Russian).
4. Common Attack Pattern Enumeration and Classification (CAPEC). URL: <https://capec.mitre.org> (date of access 20.10.2015).
5. The Web Application Security Consortium (WASC). URL: <http://www.webappsec.org/> (date of access 12.10.2015).
6. Positive Technologies. Ujzvimosti veb-prilozhenij: situacija ne uluchshaetsja [Vulnerabilities web applications: the situation is not improving]. URL: <http://habrahabr.ru/company/pt/blog/268779/> (date of access 16.10.2015). (In Russian).
7. IBM developerWorks. Prover'te vashi prilozhenija na ujzvimosti iz spiska OWASP Top 10 za 2013 god [Check your applications for vulnerabilities from the OWASP Top 10 for 2013]. URL: <https://www.ibm.com/developerworks/ru/library/se-owasp-top10/> (date of access 15.10.2015). (In Russian).
8. Statistika ujzvimostej veb-prilozhenij (2014 g.) [Statistics of vulnerabilities in web applications (2014)]. URL: http://www.ptsecurity.ru/lab/analytics/WEB_APP_VULNERABILITY_2014.A4.RUS.242465.14.OCT.2015.pdf (date of access 16.10.2015).
9. Welcome to OWASP the free and open software security community. URL: https://www.owasp.org/index.php/Main_Page (date of access 20.10.2015).
10. Barskij A.B. Nejronnye seti: raspoznavanie, upravlenie, prinyatie reshenij [Neural networks: recognition, management, decision making]. Moscow, Finansy i statistika, 2004. 176 p. (In Russian).
11. Zaencev I.V. Nejronnye seti: osnovnye modeli [Neural networks: basic models]. Voronezh, Voronezhskiy gosudarstvennyy universitet Publ. 1999. 76 p. (In Russian).

Information about authors:

Solovyov S.V., Ph.D., the Head of Department of FAI "SSRTI PTISI FSTEC of Russian Federation";

Mamuta V.V., the researcher of FAI "SSRTI PTISI FSTEC of Russian Federation".

For citation:

Solovyov S.V., Mamuta V.V. Using neural network technologies apparatus for determination of the actual information security threats for information systems. H&ES Research. 2016. Vol. 8. No. 5. Pp. 78–82.